PROJET SPOTIFY

Politique de gouvernance des données

Étape 2 - Conception du cadre de gouvernance des données

AUTEUR Aïcha FATHELLAH

OBJET Cadre unique de gouvernance des données de Spotify

VERSION 1.0

DATE Septembre 2026

1. Objet et périmètre

Objet

La présente politique définit le cadre unique de gouvernance des données (data governance) de Spotify. Elle a pour but de garantir la qualité, la sécurité, la confidentialité et la conformité des données, tout en assurant leur disponibilité et leur exploitation efficace au service des objectifs de l'entreprise. Elle constitue le document de référence auquel se rattachent l'ensemble des règles, des procédures et des responsabilités relatives aux données.

Périmètre

La politique s'applique à l'ensemble du patrimoine de données de Spotify, quels que soient sa nature et son lieu de traitement : journaux d'activité des utilisateurs, métadonnées des morceaux et des podcasts, données démographiques, informations d'abonnement et de facturation, indicateurs d'engagement des campagnes marketing. Elle couvre tous les systèmes qui hébergent ou traitent ces données (lacs de données, bases relationnelles, stockage cloud), tous les départements (marketing, produit, ingénierie, curation de contenu) et toutes les régions où l'entreprise opère.

Personnes concernées

La politique engage l'ensemble des collaborateurs de Spotify, y compris les prestataires et partenaires ayant accès aux données. L'accessibilité des règles et des outils est garantie pour tous, y compris les personnes en situation de handicap.

2. Principes directeurs

La gouvernance des données de Spotify repose sur neuf principes fondateurs. Ils s'appliquent à toutes les activités liées aux données et servent de grille d'arbitrage en cas de doute.

1. Responsabilité (accountability). Chaque jeu de données a un responsable identifié. Des gestionnaires de données (data stewards) et un délégué à la protection des données (data protection officer, DPO) garantissent le respect des normes organisationnelles, éthiques et légales.

2. Transparence. Toute activité de traitement (collecte, stockage, partage) est communiquée clairement aux utilisateurs, au moyen d'avis de confidentialité et d'une gestion du consentement.

3. Sécurité. Les données sensibles, notamment les données personnelles et de paiement, sont chiffrées et protégées selon les normes les plus élevées (PCI-DSS pour les paiements).

4. Qualité. Les données collectées et traitées sont exactes, complètes et fiables, et font l'objet d'audits réguliers.

5. Conformité. Les traitements respectent le RGPD, le CCPA et la norme PCI-DSS : licéité, consentement et respect des droits des personnes.

6. Minimisation (data minimization). Seules les données nécessaires à une finalité précise sont collectées et conservées.

7. Droits des utilisateurs. Chaque utilisateur peut accéder à ses données, les rectifier, les supprimer et s'opposer à leur collecte ou à leur vente.

8. Amélioration continue. Le cadre évolue avec la réglementation, la technologie et les besoins de l'entreprise, au moyen de révisions régulières.

9. Usage éthique. L'utilisation de l'intelligence artificielle et des traitements automatisés est transparente, surveillée et exempte de biais.

3. Rôles, responsabilités et instances

La gouvernance des données distingue trois niveaux de responsabilité, qu'il convient de ne pas confondre : la gouvernance définit les règles, la gestion les applique, l'analyse exploite les données. Cette séparation garantit qu'aucun acteur ne contrôle ses propres pratiques.

Les rôles clés sont les suivants. Le directeur des données (chief data officer, CDO) porte la stratégie de gouvernance et l'aligne sur les objectifs de l'entreprise. Le délégué à la protection des données (DPO) veille à la conformité et fait le lien avec les autorités de régulation. Les gestionnaires de données (data stewards) garantissent l'application des règles sur leur domaine. Le comité de gouvernance des données (data governance committee), réunissant les représentants des principaux départements, examine et valide les politiques. Les responsables métier (ingénierie, marketing, produit) et l'équipe juridique portent la responsabilité opérationnelle sur leur périmètre.

L'attribution des responsabilités suit la matrice RACI ci-dessous : pour chaque activité liée aux données, plusieurs acteurs peuvent réaliser le travail (R), mais une seule personne en répond et tranche (A). La place de chaque rôle dans l'organisation figure dans l'organigramme annexé à la présente politique.

Activité	CDO	Comité	DPO	Juridique	Direction propriétaire du domaine	Responsable ingénierie	Data Steward du domaine	Data Steward IA
Définir la stratégie de gouvernance	**A/R**	C	C	C	C	C	I	I
Examiner et valider les politiques et standards	**A**	R	C	C	C	C	I	I
Fixer les exigences de qualité d'un domaine (indicateur, seuil)	I	I			**A**		R	C
Profiler et corriger les données (remédiation)	I				**A**	C	R	
Attribuer les droits d'accès (RBAC, moindre privilège)	I		C		**A**	R	R	
Sécuriser l'infrastructure (chiffrement, journalisation, PCI-DSS)	I		C	C		**A/R**	I	
Contrôler la conformité RGPD et CCPA (audits, écarts)	I	I	**A/R**	C	C		C	
Surveiller les biais et les données d'entraînement de l'IA	I	I	C		C			**A/R**

R : réalise. A : répond du résultat et tranche, un seul par activité. C : consulté. I : informé.
Matrice RACI des activités de gouvernance des données.

4. Qualité des données

La qualité ne se mesure jamais globalement, mais dimension par dimension. Les dimensions retenues sont l'exhaustivité, l'exactitude, la cohérence, la traçabilité de l'origine (lineage) et l'unicité. Deux activités structurent la démarche : le profilage (data profiling), qui évalue l'état des données selon une dimension explicite, et la remédiation (data remediation), qui corrige, nettoie et normalise les données défaillantes.

Toute exigence de qualité s'accompagne d'un indicateur chiffré, d'un seuil d'acceptation et d'un responsable désigné. La priorité porte sur les jeux de données qui influencent directement l'expérience utilisateur, à savoir les données alimentant l'algorithme de recommandation et les métadonnées de contenu.

5. Conformité réglementaire

Les traitements de Spotify respectent trois cadres. Le RGPD impose le consentement explicite, le droit d'accès, de rectification et de suppression, ainsi que la notification des violations sous 72 heures. Le CCPA

garantit aux utilisateurs le droit de refuser la collecte ou la vente de leurs données. La norme PCI-DSS encadre le traitement des informations de paiement.

Compte tenu de l'implantation mondiale de l'entreprise, le cadre s'adapte aux réglementations régionales (par exemple le PDPA à Singapour) tout en maintenant une cohérence d'ensemble. Des audits réguliers, conduits sous la supervision du DPO, mesurent l'écart entre les règles écrites et les pratiques réelles.

6. Sécurité et contrôle d'accès

La sécurité repose sur le principe du moindre privilège : chacun accède à ce qui lui est strictement nécessaire, et à rien de plus. Le contrôle d'accès s'appuie sur les rôles (role-based access control, RBAC), les droits étant attachés à des rôles et non à des individus. Les données sensibles sont chiffrées, les échanges protégés et les consultations journalisées.

L'anonymisation des jeux de données est requise avant tout partage ou toute exploitation secondaire. Un protocole de réponse aux violations définit les actions à mener en cas d'incident.

7. Cycle de vie et classification des données

Chaque donnée est classée selon sa nature : données transactionnelles, données maîtres (master data), données de référence et métadonnées. Cette classification, complétée par un niveau de sensibilité, détermine les exigences de qualité et les droits d'accès applicables.

Le cycle de vie suit le modèle POSMAD : planifier, obtenir, stocker et partager, entretenir, appliquer, puis archiver ou supprimer. Au terme de la durée légale de conservation, les données détaillées sont supprimées et seuls les agrégats nécessaires sont conservés, ce qui réduit aussi l'empreinte de stockage.

8. Gouvernance de l'intelligence artificielle et éthique

L'algorithme de recommandation étant au cœur du service, ses usages font l'objet d'une vigilance particulière. Les jeux d'entraînement sont choisis avec soin, car un modèle reproduit et amplifie les biais présents dans ses données. La diversité des équipes qui conçoivent les systèmes constitue le moyen le plus efficace de repérer un biais avant sa mise en production.

Les systèmes de décision automatisée sont surveillés, explicables et transparents : l'utilisateur est informé lorsqu'il interagit avec un contenu recommandé par une intelligence artificielle. Des lignes directrices éthiques sont intégrées à tout projet de traitement de données ou de développement d'IA.

9. Pilotage, indicateurs et audits

Un dispositif de gouvernance s'évalue comme le reste : au moyen d'indicateurs chiffrés, d'audits réguliers et d'une veille organisée.

Les indicateurs de pilotage retenus sont notamment la part des jeux de données critiques dotés d'un propriétaire identifié, la part disposant d'un contrat de données (data contract), le délai moyen de correction d'une anomalie de qualité, et le taux de couverture des systèmes cartographiés au regard de leur niveau de risque.

Des audits réguliers mesurent l'écart entre les règles écrites et les pratiques réelles, et débouchent sur un plan d'amélioration. Une veille sur les évolutions réglementaires et technologiques permet d'anticiper leurs effets plutôt que de les subir. Conformément au principe d'amélioration continue, la présente politique fait l'objet d'une révision périodique intégrant les retours d'expérience et les nouvelles bonnes pratiques.